

Risk ID	Asset ID	Asset Name	Threat Description	Likelihood (1-5)	Impact (1-5)	Risk Score (L x I)
R-001	A-002	Customer PII Records	Data breach exposing customer PII due to unauthorized access or insider threat	4	5	20
R-002	A-008	Payment Gateway (Stripe)	Magecart skimming attack injects malicious code to capture live card data from every transaction			15
R-003	A-003	E-Commerce Web Application	SQL injection or code injection attack exploits application vulnerability to extract database contents			20
R-004	A-003	E-Commerce Web Application	DDoS attack overwhelms web application causing extended downtime and lost revenue			16
R-005	A-013	Admin / Privileged Accounts	Privilege abuse by disgruntled employee — deletes or exfiltrates critical data before termination			15
R-006	A-013	Admin / Privileged Accounts	Credential compromise via phishing — attacker gains admin access through stolen credentials			20
R-007	A-007	Cloud Hosting (AWS)	Misconfigured cloud storage (S3 bucket) exposes sensitive company or customer data publicly			12

Risk ID	Asset ID	Asset Name	Threat Description	Likelihood (1-5)	Impact (1-5)	Risk Score (L x I)
R-008	A-010	Business Email System	Business Email Compromise (BEC) — attacker impersonates executive to authorize fraudulent wire transfer	3	4	12
R-009	A-012	Backup System	Ransomware encrypts primary systems and backup — company cannot recover without paying ransom			20
R-010	A-011	Network Router / Firewall	Firewall misconfiguration leaves internal network ports exposed, enabling unauthorized access		4	8

Risk Level	Recommended Control	Control Type	Notes / Justification
Critical	Implement data encryption at rest and in transit; enforce role-based access control (RBAC); conduct quarterly access reviews	Preventive / Detective	Likelihood 4: High-value target; small companies increasingly targeted. Impact 5: FTC action, lawsuits, credit monitoring costs, brand damage.
High	Implement Content Security Policy (CSP) headers; monitor third-party scripts; ensure PCI-DSS compliance with payment processor	Preventive / Detective	Likelihood 3: Requires technical sophistication but Magecart kits are widely available. Impact 5: PCI-DSS violation, card processing revoked, business cannot operate.
Critical	Deploy Web Application Firewall (WAF); conduct regular penetration testing; enforce input validation in application code	Preventive	Likelihood 4: Web apps are constantly probed by automated scanners. Impact 5: Full database exposure, combined with PII and payment data.
High	Enable DDoS protection via cloud provider (AWS Shield); implement rate limiting and traffic filtering	Preventive / Responsive	Likelihood 4: DDoS attacks are cheap to execute and frequently target e-commerce. Impact 4: Direct revenue loss per hour of downtime, customer trust damage.
High	Enforce least privilege principle; implement privileged access management (PAM); disable accounts immediately upon termination	Preventive / Detective	Likelihood 3: Insider threats are less frequent but devastating. Impact 5: Irreversible data loss or theft, potential total business disruption.
Critical	Enforce Multi-Factor Authentication (MFA) on all privileged accounts; conduct phishing awareness training	Preventive	Likelihood 4: Phishing is the #1 attack vector globally. Impact 5: Admin access = full system control, data theft, ransomware deployment.
Medium	Implement cloud security posture management (CSPM); enforce bucket policies blocking public access; conduct regular cloud config audits	Preventive / Detective	Likelihood 3: Misconfiguration is the #1 cause of cloud breaches but requires internal error. Impact 4: Public data exposure, regulatory scrutiny, reputational damage.

Risk Level	Recommended Control	Control Type	Notes / Justification
Medium	Implement email authentication (DMARC, DKIM, SPF); establish verbal verification policy for financial transfers over threshold	Preventive	Likelihood 3: BEC attacks target small businesses frequently. Impact 4: Direct financial loss, no guarantee of recovery.
Critical	Maintain offline/air-gapped backups; test restoration procedures quarterly; implement endpoint detection and response (EDR)	Preventive / Responsive	Likelihood 4: Ransomware groups increasingly target SMBs. Impact 5: Total operational shutdown, ransom cost, potential permanent data loss.
Medium	Conduct regular firewall rule audits; implement network segmentation; use intrusion detection system (IDS)	Preventive / Detective	Likelihood 2: Requires internal misconfiguration error. Impact 4: Exposed internal network enables lateral movement to critical systems.